

🕒 Cập nhật tháng 8 năm 2024

[Bài đọc] Giới thiệu về Spring Security

1. Spring Security là gì?

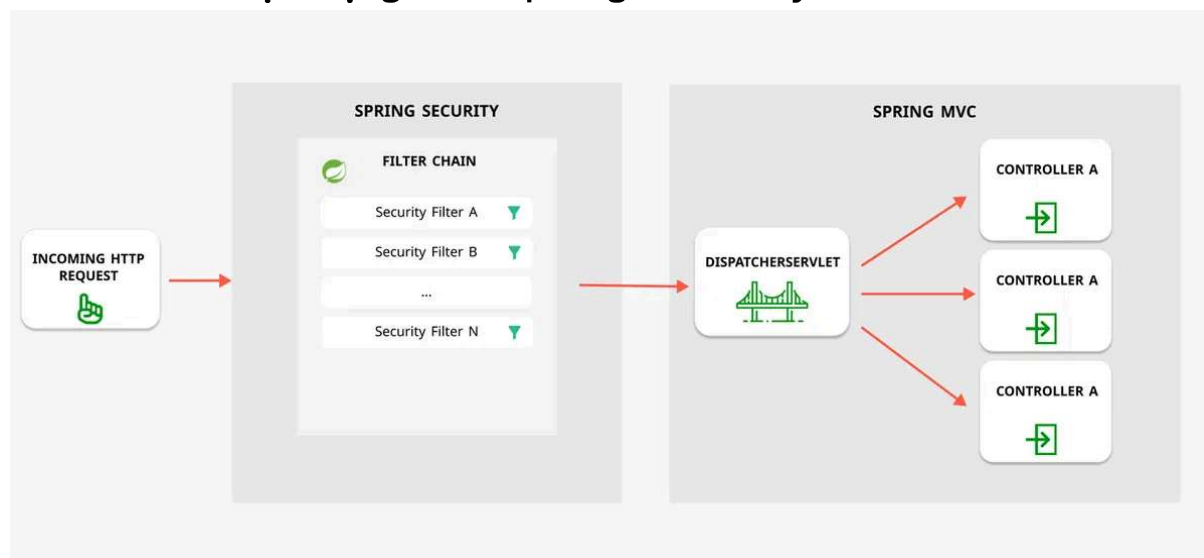
Spring Security là một framework bảo mật mạnh mẽ thuộc hệ sinh thái Spring Framework, Spring Security cung cấp các tính năng xác thực (authentication) và phân quyền (authorization) cho các ứng dụng, cũng như hỗ trợ các tiêu chuẩn và giao thức bảo mật như HTTPS, OAuth2, JWT, LDAP, SAML, OpenID Connect.

- **Xác thực (Authentication):** xác minh danh tính người dùng (ai đang đăng nhập?).
- **Phân quyền (Authorization):** kiểm soát quyền truy cập tài nguyên (người dùng được làm gì?).
- **Mã hóa mật khẩu (Password Encoding):** đảm bảo mật khẩu người dùng được lưu trữ an toàn.
- **Bảo vệ CSRF (Cross-Site Request Forgery):** ngăn chặn các cuộc tấn công giả mạo yêu cầu.
- **Bảo vệ XSS (Cross-Site Scripting):** chống chèn mã độc vào giao diện.
- **Session Management:** quản lý phiên đăng nhập và kiểm soát timeout.

2. Lợi ích khi sử dụng Spring Security

Tính năng	Mô tả
Bảo mật mặc định	Ngay khi thêm dependency, ứng dụng được bảo vệ khỏi truy cập trái phép.
Dễ tích hợp	Làm việc tốt với Spring Boot, Spring MVC, RESTful API.
Dễ tùy biến	Có thể thay đổi luồng xác thực, thêm custom login/logout handler, filter, v.v.
Hỗ trợ xác thực đa dạng	Basic, Form, JWT, OAuth2, SSO, LDAP,...

3. Cơ chế hoạt động của Spring Security



Spring Security hoạt động dựa trên mô hình **client-server**, sử dụng **Filter Chain** (chuỗi bộ lọc) để **can thiệp vào quá trình xử lý yêu cầu (request) và phản hồi (response)** của ứng dụng web.

Quy trình hoạt động:

- Client gửi request đến server.
- Request được đi qua chuỗi các Filter do Spring Security quản lý (Security Filter Chain).
- Mỗi filter thực hiện một tác vụ bảo mật:
 - Kiểm tra đăng nhập (Authentication).
 - Kiểm tra quyền truy cập (Authorization).
 - Chuyển hướng đến trang login/logout.
 - Xử lý lỗi bảo mật (như CSRF, truy cập trái phép...).
- Nếu request vi phạm bảo mật, Spring Security sinh ra sự kiện (event) để ứng dụng có thể xử lý (ghi log, hiển thị lỗi, v.v.).
- Nếu request hợp lệ, request được chuyển tiếp đến Controller như bình thường.
- Response trả về cũng đi qua filter để đảm bảo an toàn trước khi đến client.